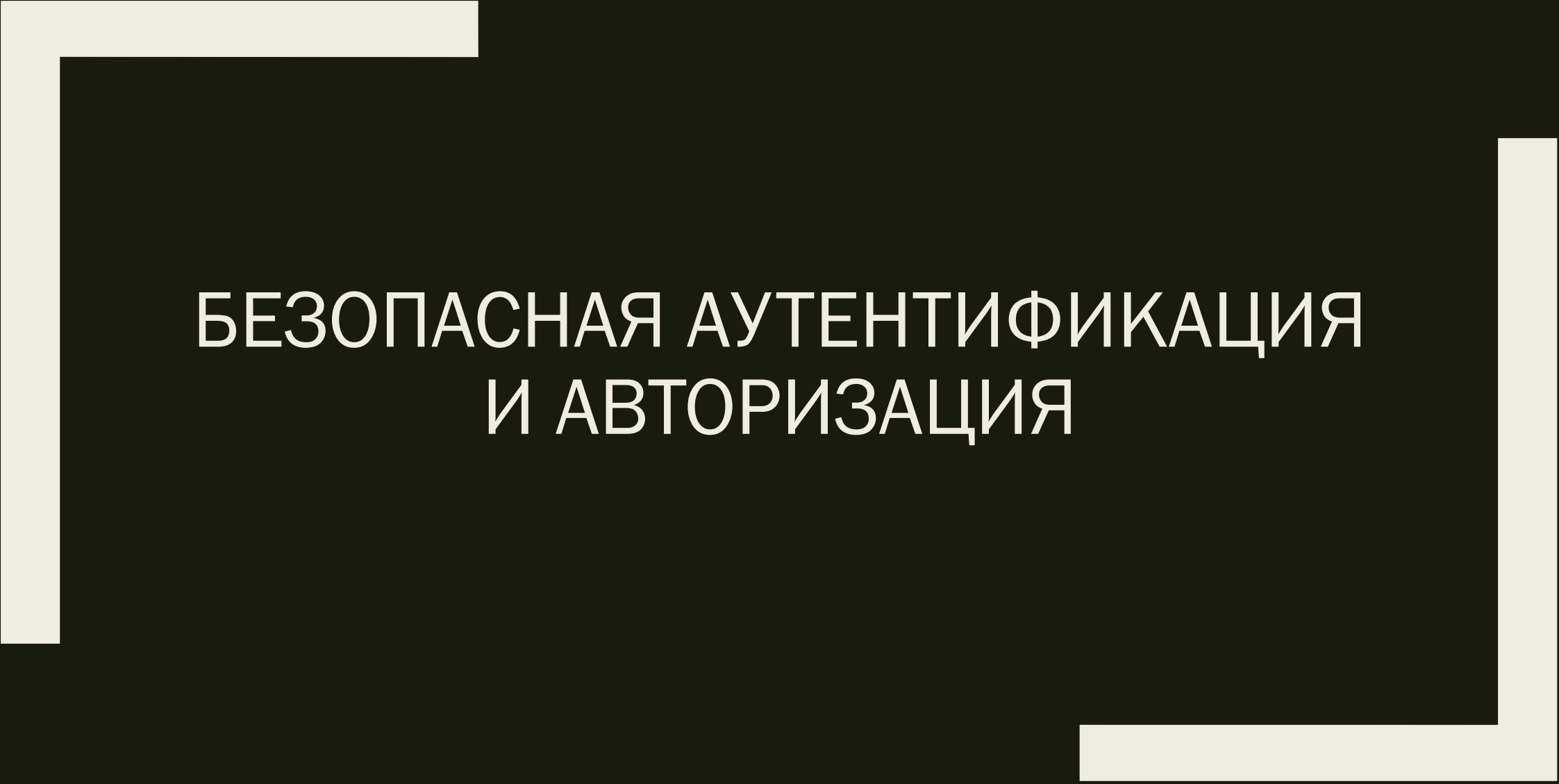




БЕЗОПАСНАЯ АУТЕНТИФИКАЦИЯ И АВТОРИЗАЦИЯ

Аутентификация

Аутентификация — процедура проверки подлинности, например: проверка подлинности пользователя путём сравнения введённого им пароля с паролем, сохранённым в базе данных пользовательских логинов; подтверждение подлинности электронного письма путём проверки цифровой подписи письма по открытому ключу отправителя;

Аутентификация

В Web-системах для проведения аутентификации в большинстве случаев участвует пара значений — **ИМЯ ПОЛЬЗОВАТЕЛЯ** и **ПАРОЛЬ**, удостоверяющий, что пользователь действительно тот, за кого себя выдает. Считается, что никто, кроме самого пользователя, не знает пароль. Естественно, известны более сложные и более надежные методы аутентификации, в частности **биометрические**, но в Web-системах они практически не применяются.

Авторизация

Авторизация — предоставление определённому лицу или группе лиц прав на выполнение определённых действий; а также процесс проверки данных прав при попытке выполнения этих действий. Часто можно услышать выражение, что какой-то человек «авторизован» для выполнения данной операции — это значит, что он имеет на неё право.

Авторизация

Система авторизации может быть построена на нескольких принципах:

Авторизация с распределением пользователей по группам

Пользователи разделяются на группы, и для каждой группы определяются права на доступ к тому или иному документу, права выполнять те или иные действия.

Авторизация

Авторизация с присвоением уровня доступа

Каждому пользователю присваивается **уровень доступа**, а каждому документу и каждому действию — **минимальный уровень доступа**, который должен быть у пользователя для того, чтобы выполнить действие или получить доступ к документу.

Авторизация

Табличный уровень доступа

Каждому пользователю для каждого документа или действия присваивается значение, отвечающее за уровень доступа пользователя к этому документу. Другими словами, для каждого документа или действия определен список пользователей, которые имеют право доступа к этому документу или имеют право выполнять данное действие.

Длинный URL

Наиболее просто реализуемый метод аутентификации (и одновременно авторизации) — сделать **путь URL того или иного ресурса длинным и бессмысленным**.

Например, для получения доступа к административной панели некоторой системы необходимо зайти по данному адресу:

`http://site/jash47gdnc023nvs0sdvgh34234khsdg0wjsdnbv.php`

При этом более **никакой аутентификации не проводится**.

Длинный URL

Очевидно, что если на самом сайте не будет ссылок на этот адрес и это адрес будет держаться в секрете, то подбор такого URL для злоумышленника будет довольно сложной задачей, сопоставимой с подбором самого пароля. Можно считать, что пароль содержится в самом URL-адресе.

Однако этот метод имеет огромное количество недостатков, которые сводят надежность метода к нулю.

Длинный URL

- ❑ URL никакими системами не рассматривается как информация, которая может содержать секретные сведения.
- ❑ URL могут попадать в log-файлы HTTP-сервера, прокси-сервера. А, следовательно, нет никакой гарантии, что эти сведения не будут доступны третьим лицам.
- ❑ Также нельзя гарантировать, что адрес не попадет в базы данных поисковых систем, а попасть он туда может если ссылка на указанный адрес была в открытом доступе, и поисковый робот успел ее проиндексировать.

Длинный URL

Применять данную политику можно разве что в ситуациях, когда предоставляется доступ к данным, не имеющим конфиденциального характера, однако они могут быть интересны только ограниченному кругу лиц. Причем от утечки этих данных обладатель не должен нести никакого ущерба.

Система аутентификации со стороны клиента

В некоторых случаях сама аутентификация целиком проводится на стороне клиента, а серверу лишь посылается ее результат. Как подтип такой аутентификации может быть, что клиент переадресовывается на некоторый длинный URL в случае удачного прохождения аутентификации.

В любом случае независимо от реализации такую систему аутентификации нельзя назвать достаточно хорошей. Практически, она даже хуже системы с длинным URL.

Система аутентификации со стороны клиента

Очевидно, что подобная система не представляет никакой преграды перед нападающим. Полный текст HTML-страницы доступен любому, даже не аутентифицированному пользователю, и **любой пользователь, просматривая исходный код, сможет выявить всю информацию, необходимую для проведения аутентификации.**

Одиночный пароль

В некоторых случаях для аутентификации пользователя используется одиночный пароль. При этом у каждого пользователя он свой. Имя пользователя или логин в аутентификации не используются.

Эта система тоже ненадежна. При такой политике у пользователей не должно быть одинаковых паролей, иначе их нельзя будет отличить. Теперь представим ситуацию, когда в системе регистрируется новый пользователь и вводит, уже имеющийся, пароль. Очевидно, что система должна отказать в регистрации, тем самым пароль будет раскрыт.

Одиночный пароль

Причем для прохождения аутентификации в качестве пользователя даже не нужно знать имя пользователя, так как аутентификация проходит только с использованием пароля.

Подобную систему можно использовать только тогда, когда заранее известно, что у системы будет минимальное количество пользователей, или если пользователь будет один.

Одиночный пароль

Ниже представлен список наиболее часто встречающихся уязвимостей в случае использования аутентификации по паролю:

- Веб-приложение позволяет пользователям создавать простые пароли.
- Веб-приложение не защищено от возможности перебора паролей (brute-force attacks).
- Веб-приложение само генерирует и распространяет пароли пользователям, однако не требует смены пароля после первого входа (т.е. текущий пароль где-то записан).
- Веб-приложение допускает передачу паролей по незащищенному HTTP-соединению, либо в строке URL.

Одиночный пароль

- Веб-приложение не использует безопасные хэш-функции для хранения паролей пользователей.
- Веб-приложение не предоставляет пользователям возможность изменения пароля либо не уведомляет пользователей об изменении их паролей.
- Веб-приложение использует уязвимую функцию восстановления пароля, которую можно использовать для получения несанкционированного доступа к другим учетным записям.
- Веб-приложение не требует повторной аутентификации пользователя для важных действий: смена пароля, изменения адреса доставки товаров и т. п.

Одиночный пароль

- Веб-приложение создает session tokens таким образом, что они могут быть подобраны или предсказаны для других пользователей.
- Веб-приложение допускает передачу session tokens по незащищенному HTTP-соединению, либо в строке URL.
- Веб-приложение не устанавливает флаги HttpOnly и Secure для browser cookies, содержащих session tokens.
- Веб-приложение не уничтожает сессии пользователя после короткого периода неактивности либо не предоставляет функцию выхода из аутентифицированной сессии.

Имя и пароль

Наиболее распространенный способ аутентификации. Нередко в качестве имени может служить кодовый номер или адрес электронного ящика. При правильной реализации подобная система первичной аутентификации будет достаточно надежна для большинства Web-систем.

Наиболее часто встречающейся ошибкой при реализации такого метода является то, что пароль передается HTTP-методом GET, параметры которого могут полностью легироваться как на промежуточных прокси-серверах, так и на HTTP-сервер системы.

Имя и пароль

В случае передачи имени пользователя методом HTTP POST система будет избавлена от подобных недостатков.

Стоит отметить, что **пароль на сервер все равно будет передаваться в открытом виде и может быть перехвачен на любом промежуточном узле.** Для защиты от подобного перехвата **используется протокол HTTPS.** В этом случае перехват трафика ничего не даст.

Аутентификация по одноразовым паролям

Аутентификация по одноразовым паролям обычно применяется дополнительно к аутентификации по паролям для реализации two-factor authentication (2FA). В этой концепции пользователю необходимо предоставить данные двух типов для входа в систему: что-то, что он знает (например, пароль), и что-то, чем он владеет (например, устройство для генерации одноразовых паролей). Наличие двух факторов **позволяет в значительной степени увеличить уровень безопасности**, что может быть востребовано для определенных видов веб-приложений.

Аутентификация по одноразовым паролям

Другой популярный сценарий использования одноразовых паролей — дополнительная аутентификация пользователя во время выполнения важных действий: перевод денег, изменение настроек и т. п.

Аутентификация по одноразовым паролям

Существуют разные источники для создания одноразовых паролей. Наиболее популярные:

Аппаратные или программные токены, которые могут генерировать одноразовые пароли на основании секретного ключа, введенного в них, и текущего времени. Секретные ключи пользователей, являющиеся фактором владения, также хранятся на сервере, что позволяет выполнить проверку введенных одноразовых паролей.

Аутентификация по одноразовым паролям

Случайно генерируемые коды, передаваемые пользователю через SMS или другой канал связи. В этой ситуации фактор владения — телефон пользователя (точнее — SIM-карта, привязанная к определенному номеру).

Распечатка или scratch card со списком заранее сформированных одноразовых паролей. Для каждого нового входа в систему требуется ввести новый одноразовый пароль с указанным номером.

Аутентификация по токенам

Такой способ аутентификации чаще всего применяется при построении распределенных систем Single Sign-On (SSO), где одно приложение (service provider или relying party) делегирует функцию аутентификации пользователей другому приложению (identity provider или authentication service). Типичный пример этого способа — вход в приложение через учетную запись в социальных сетях. Здесь социальные сети являются сервисами аутентификации, а приложение доверяет функцию аутентификации пользователей социальным сетям.

Аутентификация по токенам

Реализация этого способа заключается в том, что identity provider (IP) предоставляет достоверные сведения о пользователе в виде токена, а service provider (SP) приложение использует этот токен для идентификации, аутентификации и авторизации пользователя.

Сам токен обычно представляет собой структуру данных, которая содержит информацию, кто сгенерировал токен, кто может быть получателем токена, срок действия, набор сведений о самом пользователе (claims). Кроме того, токен дополнительно подписывается для предотвращения несанкционированных изменений и гарантий подлинности.

Аутентификация по токенам

При аутентификации с помощью токена SP-приложение должно выполнить следующие проверки:

- Токен был выдан доверенным identity provider приложением (проверка поля issuer).
- Токен предназначенся текущему SP-приложению (проверка поля audience).
- Срок действия токена еще не истек (проверка поля expiration date).
- Токен подлинный и не был изменен (проверка подписи).